

Laporan Audit & Panduan Keamanan ExspanApp (MiniProject KPI EWI)

Dokumen ini disusun untuk memberikan gambaran menyeluruh mengenai sistem keamanan yang ada di aplikasi ExspanApp. Laporan ini mencakup aspek teknis (untuk pengembang) dan penjelasan sederhana (untuk pengguna umum/pemilik bisnis) agar semua pihak memahami bagaimana data mereka dilindungi.

Daftar Isi

1. Ringkasan Eksekutif
 2. Keamanan Akun & Proteksi Login
 3. Keamanan Database (PostgreSQL vs Firebase)
 4. Keamanan Data dalam Perjalanan (Data in Transit)
 5. Integritas Data & Proteksi Kode
 6. Menghadapi Serangan Umum (Hacker 101)
 7. Saran Peningkatan (Roadmap Keamanan)
-

1. Ringkasan Eksekutif

Aplikasi ini dibangun dengan prinsip “**Defense in Depth**” (Pertahanan Berlapis). Artinya, jika satu lapisan ditembus, masih ada lapisan lain yang melindungi data Anda.

- **Bahasa Teknis:** Implementasi meliputi *Rate Limiting*, *JWT Stateless Auth*, *Password Hashing with Salt*, dan *ORM-based SQL Injection Mitigation*.
 - **Bahasa Gampang:** Aplikasi ini punya banyak lapis pintu. Ada pagar depan (Rate Limit), ada kunci pintu (Password Hashing), dan ada satpam yang memeriksa tiket (JWT).
-

2. Keamanan Akun & Proteksi Login

A. Proteksi “Tembak” Password (Brute-Force Protection)

Salah satu ancaman terbesar adalah hacker yang mencoba ribuan password dalam waktu singkat menggunakan robot (Brute Force).

- **Penjelasan Teknis:** Kita menggunakan **Flask-Limiter** di endpoint `/api/auth/login`. Batas saat ini adalah **5 percobaan per menit**. Jika melampaui batas ini, IP Address pengirim akan diblokir sementara oleh server (HTTP 429 Too Many Requests).

- **Bahasa Gampang:** Ini seperti kunci pintu yang “ngambek” kalau dicoba pakai kunci salah 5 kali berturut-turut. Orang tidak bisa terus-menerus mencoba password dengan cepat karena server akan mendinginkan mereka selama beberapa menit.

B. Penyimpanan Password (Password Hashing)

Kami tidak pernah menyimpan password asli Anda di database.

- **Penjelasan Teknis:** Password diolah menggunakan algoritma **PBKDF2 dengan SHA256**. Saat Anda mendaftar, password diubah menjadi “hash” unik yang tidak bisa dikembalikan ke bentuk aslinya (One-way hash).
- **Bahasa Gampang:** Password Anda seperti buah yang dimasukkan ke blender. Kami hanya menyimpan “jus”-nya saja di database. Kalau database dicuri, pencuri hanya dapat jusnya dan tidak tahu buah aslinya apa. Mereka tidak bisa mengubah jus itu kembali jadi buah utuh.

C. Sistem Tiket Akses (JWT - JSON Web Token)

Setelah login, Anda tidak perlu mengirim password lagi setiap kali membuka halaman.

- **Penjelasan Teknis:** Server memberikan token JWT yang ditandatangani secara digital menggunakan **JWT_SECRET_KEY**. Token ini terdiri dari **Header**, **Payload**, dan **Signature**. Jika Signature tidak cocok, akses ditolak. Token berlaku selama **7 hari**.
- **Bahasa Gampang:** Mirip gelang tiket di Dufan. Sekali masuk dan dapat gelang, Anda bebas naik wahana apa saja selama gelangnya masih sah (7 hari). Anda tidak perlu bolak-balik ke loket (login) tiap mau naik wahana.

3. Keamanan Database (PostgreSQL vs Firebase)

A. PostgreSQL (Database Relasional - Saat Ini)

PostgreSQL adalah database profesional yang sangat kuat dan fleksibel. Di aplikasi ini, PostgreSQL berperan sebagai “Gudang Data Pusat”.

- **Penjelasan Teknis:**
 1. **Access Control (pg_hba.conf):** Konfigurasi ini mengatur “siapa yang boleh bicara”. Biasanya hanya alamat IP server backend yang diizinkan terhubung.
 2. **User Roles & Privileges:** Kita tidak menggunakan user **postgres** (super-user) untuk aplikasi harian. Kita menggunakan user terbatas (**app_user**) yang hanya bisa melakukan **SELECT**, **INSERT**, **UPDATE** pada tabel tertentu.

3. **SQL Injection Mitigation:** Melalui SQLAlchemy, semua query menggunakan *bound parameters*. Ini mencegah karakter jahat dieksekusi sebagai perintah SQL.
 4. **Transaction Integrity:** PostgreSQL menjamin bahwa jika ada kegagalan saat menyimpan data, data tidak akan korup (prinsip ACID).
- **Bahasa Gampang:**
 - Database kita seperti brankas bank. Hanya teller resmi yang punya kunci.
 - Meskipun ada orang jahat mencoba memasukkan perintah palsu lewat formulir (SQL Injection), brankas kita sudah punya sistem sensor yang tahu mana uang asli dan mana kertas kosong.

B. Firebase (Google - NoSQL Cloud)

Jika aplikasi ingin pindah ke Firebase, pendekatannya berubah dari “koneksi server” menjadi “aturan keamanan”.

- **Penjelasan Teknis:**
 1. **Firebase Security Rules:** Aturan ditulis dalam bahasa deklaratif. Contoh: `allow write: if request.auth != null && request.auth.uid == userId.`
 2. **Firestore Identity Integration:** Keamanan menyatu dengan Firebase Auth.
 3. **App Check:** Mencegah aplikasi liar (bukan aplikasi resmi Anda) untuk mengakses database.
- **Bahasa Gampang:**
 - Firebase itu seperti menitipkan data di brankas digital milik Google. Google yang menjaga pintunya 24 jam.
 - Kita cukup kasih daftar ke Google: “Siapa saja yang boleh masuk”.

C. Tabel Perbandingan (Postgres vs Firebase)

Fitur	PostgreSQL	Firebase (Google)
Kontrol	Penuh (Kita pegang kuncinya)	Terkelola (Google pegang kuncinya)
Keamanan Utama	Firewall & SQL Parameterization	Security Rules & App Check
Lokasi Data Ketahanan	Server Sendiri / VPS Sangat Tinggi (Bisa Backup Mandiri)	Server Google (Global) Sangat Tinggi (Otomatis Backup Google)
Bahasa Gampang	“Bangun Brankas Sendiri”	“Sewa Brankas di Bank Besar”

4. Keamanan Data dalam Perjalanan (Data in Transit)

A. Penggunaan HTTPS/SSL

Bagaimana jika hacker mengintip data saat dikirim dari HP ke Server?

- **Penjelasan Teknis:** Sangat disarankan menggunakan **HTTPS (SSL/TLS)**. Ini mengenkripsi semua data sebelum dikirim lewat internet. Tanpa HTTPS, token JWT bisa disadap di jaringan WiFi publik (Man-in-the-Middle Attack).
 - **Bahasa Gampang:** Ini seperti mengirim surat di dalam kotak besi gembok. Tukang pos atau orang di jalan bisa lihat kotaknya, tapi mereka tidak bisa baca isi surat di dalamnya karena tidak punya kuncinya.
-

5. Integritas Data & Proteksi Kode

A. Audit Trail & Notifikasi

- Setiap tindakan penting (seperti menyetujui anggaran) akan mencatat siapa aktornya dan mengirim notifikasi ke Manager. Ini mencegah aksi diam-diam.
- **Bahasa Gampang:** Setiap kali ada yang mengubah data penting, sistem akan “teriak” memberi tahu bos lewat notifikasi.

B. Sanitisasi Upload File

- **Penjelasan Teknis:** Nama file asli diubah menjadi kode unik (**uuid**) dan ekstensinya diperiksa ketat (hanya gambar/PDF). File disimpan di folder terisolasi.
 - **Bahasa Gampang:** Jika ada yang mau titip file (nota), kita periksa dulu isinya jangan sampai ada bom/virus di dalamnya. Kita juga kasih label baru agar tidak disalahgunakan.
-

6. Menghadapi Serangan Umum (Hacker 101)

1. Serangan XSS (Cross-Site Scripting)

- **Apa itu?** Hacker mencoba memasukkan kode jahat agar HP Manager terinfeksi saat melihat data.
- **Penanganan Kita:** Flutter secara otomatis menolak eksekusi kode Javascript dari teks biasa. Data juga dibersihkan di sisi server.
- **Bahasa Gampang:** Jika ada orang iseng menulis “kode komputer” di form, aplikasi kita cuma menganggap itu “tulisan biasa” dan tidak akan menjalankannya.

2. Serangan CSRF (Cross-Site Request Forgery)

- **Apa itu?** Hacker mencoba menjebak Anda mengklik link yang otomatis menghapus data.
 - **Penanganan Kita:** Kita menggunakan JWT di Header (bukan Cookie). Link jahat dari luar tidak punya “tiket masuk” (JWT) aplikasi kita, jadi mereka tidak bisa melakukan apa-apa.
-

7. Saran Peningkatan (Roadmap Keamanan)

1. **2FA (Two-Factor Authentication):** Menambahkan verifikasi lewat WhatsApp atau Email setiap kali login dari perangkat baru.
 2. **Password Complexity:** Mewajibkan password punya huruf besar, angka, dan simbol.
 3. **Account Lockout:** Jika salah password 10 kali, akun dikunci total sampai dibuka oleh Admin.
 4. **Automatic Backup:** Melakukan backup otomatis setiap hari ke Cloud Storage (S3/Google Cloud) agar data tidak hilang jika server rusak.
-

8. Keamanan Server & Lingkungan (Environment)

Selain kode aplikasi, “rumah” tempat aplikasi berjalan (Server/VPS) juga harus dijaga.

A. Bahaya Mode Debug (Debug Mode)

- **Penjelasan Teknis:** Di file `app.py`, terdapat baris `app.run(debug=True)`. Ini sangat berguna saat coding, tapi **SANGAT BERBAHAYA** di produksi. Mode debug memungkinkan orang melihat kode sumber Anda saat terjadi error dan bahkan menjalankan perintah dari jarak jauh melalui terminal debugger.
- **Bahasa Gampang:** Mode Debug itu seperti membiarkan pintu belakang terbuka dengan CCTV yang memperlihatkan isi seluruh rumah. Saat aplikasi sudah online, pintu ini harus dikunci rapat (`debug=False`).

B. Perlindungan File Rahasia (.env)

- **Penjelasan Teknis:** Semua kunci rahasia (`JWT_SECRET_KEY`, `MAIL_PASSWORD`, `DATABASE_URL`) disimpan di file `.env`. File ini sudah masuk dalam `.gitignore` agar tidak terunggah ke internet (GitHub).
- **Bahasa Gampang:** File `.env` itu seperti daftar PIN ATM dan kunci brankas Anda. File ini tidak boleh difoto, tidak boleh dikirim lewat WA, dan tidak boleh ada di internet. Hanya server yang boleh tahu.

C. Keamanan Server (VPS/Cloud)

- **Penjelasan Teknis:** Sangat disarankan menutup semua Port kecuali 80 (HTTP), 443 (HTTPS), dan 22 (SSH). Gunakan SSH Key untuk login, bukan password biasa.
 - **Bahasa Gampang:** Server itu seperti gedung kantor. Hanya pintu depan dan pintu khusus karyawan yang boleh buka. Jendela dan pintu samping semuanya harus dipaku mati agar tidak ada penyusup.
-

9. Penanganan Error yang Aman (Error Handling)

Bagaimana aplikasi bersikap saat terjadi kesalahan?

- **Penjelasan Teknis:** Aplikasi harus menampilkan pesan error yang umum (Generic Error Message) kepada pengguna, misalnya *“Terjadi kesalahan pada sistem, silakan coba lagi”*. Jangan pernah menampilkan error database yang detail seperti *“Query Error: Table ‘users’ not found at line 45”*.
 - **Bahasa Gampang:** Kalau ada masalah, aplikasi cukup bilang “Maaf, ada gangguan”. Jangan malah cerita panjang lebar masalahnya di mana, karena hacker bisa pakai info itu untuk mencari celah.
-

Kesimpulan Akhir

Aplikasi **ExspanApp** Anda saat ini sudah memiliki fondasi keamanan yang sangat solid untuk standar aplikasi manajemen internal. Dengan mengikuti saran-saran di atas (terutama mematikan mode debug dan memasang SSL), aplikasi akan menjadi jauh lebih sulit untuk ditembus.

Ingat: Keamanan adalah proses, bukan hasil akhir. Selalu perbarui sistem dan lakukan pengecekan rutin.

Dokumen ini diperbarui secara menyeluruh pada: 29 April 2026